

Curso de pentesting práctico

Material teórico y práctico derivado de THM Fieldbook. Úsalo únicamente en sistemas propios o expresamente autorizados. La aplicación sigue siendo el playbook rápido; estos documentos explican mecanismos, razonamiento y adaptación.

Orden recomendado

1. [Programa](#)
2. [Fundamentos HTTP](#)
3. [Redes, DNS y URL](#)
4. [Encoding y parsers](#)
5. [Linux y shell](#)
6. [Bases de datos y flujo de datos](#)
7. [Metodología general](#)
8. [Construcción de payloads](#)

Los bloques de técnicas, ejercicios, exámenes, soluciones y chuletas se incorporan por lotes. El estado verificable está en [progreso](#) y la cobertura real en [mapa de fuentes](#).

Navegación

Bloque	Finalidad
01_fundamentos	Entender protocolos, intérpretes, datos y permisos
02_metodologia	Investigar con evidencia y construir pruebas mínimas
03_seguridad_web	Vulnerabilidades web cubiertas por Fieldbook
04_linux	Enumeración y escalada local
05_windows	Enumeración y escalada local
06_active_directory	Identidades, relaciones y rutas de dominio
07_redes_y_pivoting	Rutas, túneles, relay y diagnóstico
08_ejercicios	Problemas sin soluciones visibles
09_exámenes	Evaluaciones y rúbricas
10_solucionarios	Respuestas razonadas
11_chuletas	Consulta operativa concisa

Índice completo

01_fundamentos

- [Bases de datos y flujo de datos](#)
- [Encoding, normalización y parsers](#)
- [HTTP, formularios, cookies y sesiones](#)
- [Linux, procesos, permisos y shell](#)
- [Redes, DNS, puertos y URLs](#)

02_metodologia

- Construcción y adaptación de payloads
- Metodología de laboratorio y room

03_seguridad_web

- Modelo de pruebas de API
- Inyeccion de argumentos (no es command injection)
- Autenticacion y sesiones en APIs
- Controles client-side y validacion del servidor
- Command Injection (inyeccion de comandos de SO)
- Enumeracion web con respuestas comodin (wildcard)
- Subida de ficheros a shell
- Seguridad de GraphQL
- IDOR / Broken Object Level Authorization (BOLA)
- Seguridad de JWT
- Local File Inclusion (LFI)
- De LFI a ejecucion (RCE)
- Bypass de OTP/MFA por manipulacion de parametros
- OAuth, OIDC y CORS
- Inyeccion SQL (SQLi)
- Server-Side Request Forgery (SSRF)
- Server-Side Template Injection (SSTI)
- Atacar WordPress
- Cross-Site Scripting (XSS)
- XML External Entity (XXE)

04_linux

- Linux capabilities
- Tareas cron escribibles
- Docker y escapes de contenedor
- Enumeracion para privesc en Linux
- Grupos peligrosos (docker, lxd, disk)
- Exploits de kernel (ultimo recurso)
- NFS con no_root_squash
- Secuestro de PATH
- Python library hijacking
- Abuso de sudo
- Sudo con env_keep (LD_PRELOAD)
- Binarios SUID
- Inyeccion por comodin (wildcard)
- Ficheros sensibles escribibles

05_windows

- AlwaysInstallElevated
- Secuestro de DLL
- Enumeracion para privesc en Windows
- Exploits de kernel en Windows (ultimo recurso)
- Autoruns y binarios de arranque
- Privilegios SeBackup / SeRestore
- Servicios mal configurados
- Credenciales guardadas en Windows
- Impersonation de token (familia Potato)
- Bypass de UAC

06_active_directory

- AD CS y certificados abusables
- Como se ataca Active Directory
- Pass-the-Ticket, ACL y trusts en Active Directory
- AS-REP roasting y Kerberoasting
- BloodHound: el grafo de permisos
- Kerberos en dos minutos
- Enumeracion de LDAP
- Hashes NTLM y Pass-the-Hash

07_redes_y_pivoting

- Enumeracion de DNS
- Fingerprinting antes que el nombre del puerto
- Enumeracion de FTP
- Segmentacion, rutas y firewalls
- Trafico de red, poisoning y relay
- Enumeracion de NFS
- Captura y analisis de paquetes
- Diagnóstico de pivoting
- Pivoting: tuneles a la red interna
- Metodologia de reconocimiento
- Enumeracion de SMB
- Enumeracion de SMTP
- Enumeracion de SNMP
- TCP frente a UDP

08_ejercicios

- Cuaderno de ejercicios

09_exámenes

- Examen de Active Directory

- [Examen final integrador](#)
- [Examen de fundamentos](#)
- [Examen de Linux](#)
- [Examen de seguridad web](#)
- [Examen de Windows](#)

10_solucionarios

- [Soluciones razonadas del cuaderno](#)

11_chuletas

- [Active Directory](#)
- [Command Y Argument Injection](#)
- [Enumeracion Inicial](#)
- [Escalada Linux](#)
- [Estabilizacion De Shells](#)
- [File Upload](#)
- [Http Y Burp](#)
- [Interpretacion De Puertos](#)
- [Lfi Y Path Traversal](#)
- [Redes Y Pivoting](#)
- [Reverse Shells](#)
- [Sql Injection](#)
- [Ssrf](#)
- [Windows](#)

Trazabilidad y compilación

- [Matriz de trazabilidad](#)
- [Compilar PDF](#)
- [Informe de progreso](#)